

Análisis de Cabeceras HTTP

Sitio analizado: <http://blandskron.com>

Fecha: 5 de julio de 2025

Herramienta utilizada: Script personalizado en Python ([requests](#))

Modo de acceso: HTTP (no HTTPS)

Cabeceras HTTP Detectadas

Cabecera	Valor
Connection	Keep-Alive
Keep-Alive	timeout=5, max=100
content-type	text/html; charset=utf-8
x-frame-options	DENY
vary	Cookie,Accept-Encoding
x-content-type-option	nosniff
s	
referrer-policy	same-origin
cross-origin-opener-p	same-origin
olicy	

content-length 2705

content-encoding br (brotli compression)

date Sat, 05 Jul 2025 00:20:54 GMT

Análisis Específico de Seguridad

Elemento	Estado	Observaciones
Server	✗ No especificado	Buenas prácticas. Ocultar el servidor reduce la superficie de ataque.
X-Powered-By	✗ No especificado	Buenas prácticas. Evita revelar tecnología backend (PHP, ASP.NET, etc.).
Content-Type	✓ Presente (text/html; charset=utf-8)	Correctamente configurado.
Set-Cookie	✗ No especificado	No hay cookies visibles en esta respuesta. Verificar en contexto de sesión.
Strict-Transport-Security	✗ No especificado	⚠ Vulnerabilidad: Falta de HSTS permite ataques tipo <i>downgrade</i> o <i>MITM</i>
X-Frame-Options	✓ Presente (DENY)	Protege contra ataques de <i>clickjacking</i> .

X-Content-Type-Options	✓ Presente (nosniff)	Evita que el navegador interprete incorrectamente el tipo de contenido.
Referrer-Policy	✓ Presente (same-origin)	Limita la fuga de información en las cabeceras Referer .
Cross-Origin-Opener-Policy	✓ Presente (same-origin)	Mejora el aislamiento entre pestañas/ventanas y mitiga ataques tipo <i>Spectre</i> .

Vulnerabilidades / Riesgos Detectados

1. No fuerza HTTPS:

- El acceso se realizó por HTTP (<http://blandskron.com>) y **no se redirigió automáticamente a HTTPS**.
- Esto expone al sitio a **ataques de interceptación (MITM)**.

2. Falta de **Strict-Transport-Security (HSTS)**:

- Esta cabecera es fundamental para asegurar que los navegadores utilicen siempre HTTPS una vez establecido.

Recomendación: Añadir cabecera:

Strict-Transport-Security: max-age=63072000; includeSubDomains; preload

○

3. No hay **Set-Cookie** (solo relevante si el sitio requiere autenticación):

- Si hay sesiones, estas deben estar protegidas con:
 - **Secure**
 - **HttpOnly**

- `SameSite=Strict` o `Lax`

Buenas Prácticas Detectadas

- **Ocultamiento de información del servidor y tecnología** (`Server`, `X-Powered-By`): Esto es positivo para seguridad.
- **Cabeceras de protección activa implementadas correctamente:**
 - `X-Frame-Options: DENY`
 - `X-Content-Type-Options: nosniff`
 - `Referrer-Policy: same-origin`
 - `Cross-Origin-Opener-Policy: same-origin`

Recomendaciones Finales

1. **Forzar HTTPS** mediante redirección automática en el servidor web.
2. **Agregar HSTS** para proteger conexiones futuras.
3. **Evaluar presencia de cookies** si se utiliza autenticación. Asegurar que tengan atributos seguros.
4. **Auditar cabeceras dinámicas** que puedan aparecer solo en rutas específicas o autenticadas (login, formularios, panel de control).
5. **Realizar un escaneo con herramientas como** [SecurityHeaders.com](https://securityheaders.com) o OWASP ZAP para una revisión automatizada.

Comparativa Técnica: HTTP vs HTTPS para blandskron.com

Cabecera	HTTP (http://)	HTTPS (https://)	Diferencia detectada
Connection	Keep-Alive	Keep-Alive	✗ No
Keep-Alive	timeout=5, max=100	timeout=5, max=100	✗ No
content-type	text/html; charset=utf-8	text/html; charset=utf-8	✗ No
x-frame-options	DENY	DENY	✗ No
vary	Cookie,Accept-Encoding	Cookie,Accept-Encoding	✗ No
x-content-type-options	nosniff	nosniff	✗ No
referrer-policy	same-origin	same-origin	✗ No
cross-origin-opener-policy	same-origin	same-origin	✗ No
content-length	2705	2705	✗ No
content-encoding	br	br	✗ No

date	Sat, 05 Jul 2025 00:20:54 GMT	Sat, 05 Jul 2025 00:24:16 GMT	✓ (esperado)
------	----------------------------------	----------------------------------	--------------

Server	No especificado	No especificado	✗ No
--------	-----------------	-----------------	------

X-Powered-By	No especificado	No especificado	✗ No
--------------	-----------------	-----------------	------

Set-Cookie	No especificado	No especificado	✗ No
------------	-----------------	-----------------	------

Strict-Transport -Security (HSTS)	✗ Ausente	✗ Ausente	✗ No mejora
--------------------------------------	-----------	-----------	-------------

Conclusión técnica:

No hay ninguna diferencia significativa entre la respuesta HTTP y HTTPS.

El servidor está sirviendo el mismo conjunto de cabeceras tanto en HTTP como en HTTPS, lo que implica lo siguiente:

⚠ Problemas persistentes:

- ✗ **No hay redirección automática de HTTP a HTTPS** (esto ya lo comprobaste manualmente al tener que ingresar manualmente la URL con `https://`).
- ✗ **Falta la cabecera Strict-Transport-Security incluso en HTTPS**, lo que impide que los navegadores recuerden que el sitio debe usarse únicamente por HTTPS en futuras visitas.
- ✗ **No mejora el nivel de seguridad al usar HTTPS**, más allá de la encriptación de la conexión, porque **no se han activado mecanismos adicionales de defensa** esperables al usar TLS.

¿Qué deberías hacer como propietario del sitio?

1. Forzar HTTPS automáticamente:

- En tu configuración del servidor (Apache, NGINX o Cloudflare), redirige automáticamente todo tráfico HTTP hacia HTTPS.

2. Añadir la cabecera **Strict-Transport-Security**:

Strict-Transport-Security: max-age=31536000; includeSubDomains; preload

- Esto **previene ataques downgrade** y permite que navegadores modernos recuerden siempre usar HTTPS.

3. Registrar el dominio en la lista preload de HSTS:

👉 <https://hstspreload.org/>